ГЛОБАЛЬНИЙ LIVE-АУДИТ STORCRYPTO ПІСЛЯ КОМІТУ В GITHUB

Дата: 28.10.2026
Production URL: https://storkcrypto.pages.dev/?audit=20261028
Платформа: Telegram Mini App / Cloudflare Pages + Functions
Роль аудиту: технічний аудитор, security reviewer і Chief Design Developer

---

1. Підсумковий статус

Фінальний статус: NOT READY

Коміт частково потрапив у live Cloudflare deployment. Є покращення, але платіжний контур, wallet connection і частина UI ще не доведені до production-ready стану.

Критичні блокери

1. Stars invoice endpoint створює замовлення без Telegram `initData`.
2. Без авторизації підставляється `userId: "tg_user"`.
3. Server-side `successful_payment` та webhook verification live-аудитом не підтверджені.
4. `/api/payments/stars/status` повертає HTML головної сторінки, а не JSON API.
5. TON Wallet Connect не підтверджений у видимому UI або main bundle.
6. У live manifest icon має формат JPG, тоді як TON Connect manifest повинен посилатися на PNG/ICO icon.
7. Academy localization перемикає active state, але видимий контент залишається змішаним українською та англійською.
8. Ринковий глобальний статус зараз `STALE`; застосунок відображає кешовані дані. Це допустимо лише за умови чесного timestamp/fallback, але потрібно перевірити поріг stale.

---

2. Що вже працює

2.1. AI Chat

Live endpoint:

```
Plain Text

POST /api/chat
```

Результат:

```
Plain Text

HTTP 200
```

Отримано:

```
JSON

{
  "reply": "pong // StorkCrypto Neural AI Core Online & Operational",
  "status": "LIVE",
  "model": "stork-neural-ai"
}
```

Висновок: попередній блокер AI Chat, який раніше повертав 502, у поточній Cloudflare-версії виправлений.

Потрібно ще перевірити:

- не лише `ping`, а реальний crypto prompt;
- timeout;
- rate limit;
- prompt injection;
- maximum message length;
- відсутність leakage system prompt;
- 10 послідовних запитів без 5xx.

2.2. Telegram validation

```
Plain Text

POST /api/validate
```

Без `initData` повертає:

Plain Text

```
HTTP 400
{"error":"Missing initData"}
```

Це позитивно, але Stars endpoint поводиться інакше й не вимагає тієї самої авторизації.

2.3. Terminal

У live UI видно понад 35 активів, зокрема:

- BTC;
- ETH;
- SOL;
- BNB;
- XRP;
- ADA;
- AVAX;
- DOT;
- TON;
- NOT;
- DOGS;
- INJ;
- TAO;
- RENDER;
- FET;
- TIA;
- SEI;
- STX;
- ONDO;
- PENDLE;
- JUP;
- ENA;

- PEPE;
- DOGE;
- SHIB;
- WIF;
- BONK;
- FLOKI;
- NEAR;
- LINK;
- SUI;
- APT;
- ARB;
- OP;
- KAS.

Це виправляє попередню проблему з відображенням лише двох монет.

2.4. Theme

Перевірено:

- `twilight` /нічний режим;
- `daylight` /денний режим;
- кнопка змінює текст `NIGHT` / `DAY`;
- class/theme root змінюється.

Темна тема краще відповідає crypto-terminal стилю. Денна тема потребує м’якшого graphite/warm-gray оформлення, щоб не створювати надмірно білий і контрастний екран.

---

3. P0 — Stars payment security failure

3.1. Факт

Запит без `Authorization`:

```
Plain Text
```

```
POST /api/payments/stars/create
Content-Type: application/json

{"plan":"pro_monthly"}
```

повернув:

```
Plain Text

HTTP 200
```

і:

```
JSON

{
  "success": true,
  "order": {
    "userId": "tg_user",
    "amount": 250,
    "currency": "XTR",
    "status": "PENDING"
  }
}
```

Підроблений header також приймається:

```
Plain Text

Authorization: tma fake-init-data
```

Результат теж — HTTP 200 з тим самим demo user.

3.2. Ризик

Це означає, що endpoint або:

- працює у demo fallback;
- не валідовує Telegram initData;
- створює invoice без реального Telegram user;
- не має server-side identity binding;
- потенційно дозволяє створювати фальшиві orders.

Це P0 security/payment blocker.

3.3. Що виправити

Для production:

```
Plain Text

Валідний Telegram initData → справжній telegram user id → order
Відсутній initData → HTTP 401
Невалідний initData → HTTP 401
Простий userId з frontend → ігнорувати
"tg_user" fallback → повністю видалити з production
```

`tg_user` допускається лише у локальному test mode, який неможливо активувати через production request і який не повинен бути зібраний у live payment path.

---

4. P0 — Немає робочого order status API

Перевірка:

```
Plain Text

GET /api/payments/stars/status?orderId=...
```

повернула:

```
Plain Text

HTTP 200
Content-Type: text/html
```

та HTML головної сторінки StorkCrypto.

Це означає, що Cloudflare Pages SPA fallback перехоплює невідомий endpoint або endpoint не реалізований.

Виправлення

Створити реальний Cloudflare Function:

```
Plain Text
```

```
/functions/api/payments/stars/status.ts
```

Він повинен:

1. Перевіряти Telegram initData.
2. Перевіряти, що order належить authenticated Telegram user.
3. Повертати лише JSON.
4. Не розкривати чужі orders.
5. Повертати `404`, якщо order не знайдений.
6. Повертати `401`, якщо авторизація відсутня.

Приклад:

JSON

```
{
  "orderId": "STARS_ORD_...",
  "status": "PENDING",
  "paymentVerified": false,
  "subscriptionActive": false
}
```

Після `successful_payment`:

JSON

```
{
  "orderId": "STARS_ORD_...",
  "status": "PAID",
  "paymentVerified": true,
  "subscriptionActive": true,
  "expiresAt": "..."
}
```

SPA fallback не повинен обробляти `/api/*` routes.

---

5. P0 — Непідтверджений Telegram payment lifecycle

Наявність `invoiceUrl` і `status: PENDING` не доводить реальну оплату.

Потрібно реалізувати та перевірити:

```
Plain Text

create invoice
→ pre_checkout_query
→ answerPreCheckoutQuery протягом 10 секунд
→ successful_payment
→ перевірка currency XTR
→ перевірка amount
→ перевірка invoice_payload
→ перевірка telegram_payment_charge_id
→ database transaction
→ PRO active
```

PRO не можна активувати після:

- натискання Pay;
- відкриття invoice;
- закриття invoice зі статусом `paid` на frontend;
- встановлення localStorage flag;
- wallet connection;
- створення PENDING order.

Telegram вимагає доставляти digital goods/services лише після `successful_payment` update `1`.

---

6. TON Wallet audit

6.1. Manifest

Live:

```
Plain Text

GET /tonconnect-manifest.json → 200
Content-Type: application/json;charset=UTF-8
Access-Control-Allow-Origin: *
```

Body:

JSON

```
{
  "url": "https://storkcrypto.pages.dev/",
  "name": "StorkCrypto",
  "iconUrl": "https://storkcrypto.pages.dev/logo.jpg"
}
```

6.2. Проблема icon

`logo.jpg` реально повертає:

Plain Text

```
Content-Type: image/jpeg
```

Для максимальної сумісності TON Connect замінити на public PNG або ICO:

Plain Text

```
https://storkcrypto.pages.dev/icon-180.png
```

Рекомендований manifest:

JSON

```
{
  "url": "https://storkcrypto.pages.dev",
  "name": "StorkCrypto",
  "iconUrl": "https://storkcrypto.pages.dev/icon-180.png",
  "termsOfUseUrl": "https://storkcrypto.pages.dev/terms",
  "privacyPolicyUrl": "https://storkcrypto.pages.dev/privacy"
}
```

6.3. Підключення не підтверджене

У видимому dashboard не знайдено явної кнопки:

Plain Text

```
Connect TON Wallet
```

У main bundle не знайдено надійних ознак змонтованих:

Plain Text

```
TonConnectUIProvider
TonConnectButton
```

Потрібно перевірити lazy chunks, але acceptance criteria прості: користувач повинен бачити кнопку в Portfolio та отримувати підтверджений connected state.

6.4. Обов’язковий UI flow

Plain Text

```
Portfolio
→ Connect TON Wallet
→ wallet picker
→ user chooses wallet
→ picker closes
→ app receives onStatusChange(wallet)
→ app shows TON Wallet connected
→ app shows shortened address
→ Disconnect works
```

Не створювати кілька providers або `TonConnectUI` instances.

Використовувати один root provider:

TSX

```
<TonConnectUIProvider manifestUrl="https://storkcrypto.pages.dev/tonconnect-man
  <App />
</TonConnectUIProvider>
```

Для status:

TSX

```
const address = useTonAddress();
const wallet = useTonWallet();
const restored = useIsConnectionRestored();
```

До `restored === true` не показувати помилково `Disconnected`.

Після `wallet !== null`:

Plain Text

```
закрити custom picker
показати Connected
показати скорочену адресу
```

TON Connect з’єднує dApp із wallet через зашифровану session і не передає застосунку приватні ключі [2].

---

7. P1 — Market data status

У live UI верхній статус:

```
Plain Text

STALE
```

При цьому в summary показано:

```
Plain Text

Market pulse stable. Monitoring whale movements.
Джерело: Binance API · Кеш (затримка)
Авто-синхронізація: 30с
```

Це краще, ніж неправдивий LIVE, але необхідно додати:

- `lastUpdatedAt`;
- точний час останнього успішного update;
- stale threshold;
- кнопку Retry;
- різницю між cached data та demo data;
- error state при повній недоступності API.

Заборонено показувати `LIVE`, якщо джерело повертає cache/stale.

---

8. P1 — Academy localization

Кнопки УКР/ENG/РУС присутні і мають `aria-pressed`, але content не локалізований повністю.

Видимий змішаний контент:

```
Рівень 1
For Beginners
Wallet security, seed phrases, risk management
Базові свічки
For Experienced
Smart Money Concepts
```

Потрібно локалізувати для кожної мови:

- title;
- description;
- level;
- tags;
- CTA;
- lesson titles;
- quiz;
- video title;
- video fallback;
- error messages.

Зміна `aria-pressed` без зміни content не є локалізацією.

---

9. P1 — Loading screen та onboarding

Live перший екран показує:

```
NODE
SYNC
BLOCK
LINK
INITIALIZING // NEURAL CORE
0%
ПРОПУСТИТИ >>
```

Після очікування відкривається onboarding:

```
AI MARKET SIGNALS
24/7 neural market surveillance...
Skip
NEXT →
```

Потрібно чітко розділити:

1. branded 6,5-секундний Manifesto loading;
2. одноразовий onboarding/tutorial.

Onboarding не повинен виглядати як зависла loading screen.

З урахуванням design preferences користувача:

- зберегти вертикальну композицію;
- не робити строкату палітру;
- зберегти темний premium crypto style;
- використовувати rotating concentric rings як основний animation motif;
- rings мають поступово трансформуватися в `StorkCrypto` при 100%;
- не використовувати `GENESIS`;
- дозволити горизонтальну data convergence у фіналі;
- не використовувати semicircle disappearance;
- pixel/fog/fracture effects мають бути контрольованими й не хаотичними;
- `StorkCrypto` повинен залишатися на одному рядку на 360×800;
- loading не повинен скидатися через випадковий lazy import.

Перевірити фактичний hard reload timing: `6,5 с ± 100 мс`.

---

10. P1 — Modal system

Live dashboard містить багато інформаційних блоків, але необхідно повторити 30-cycle test для:

- Neural Summary;
- asset detail;

- Academy lesson;
- News detail;
- Portfolio;
- PRO subscription;
- wallet status;
- error/retry;
- Analytical Companion.

Правило:

- інформаційні/технічні модалки — fullscreen;
- PRO subscription — компактний виняток;
- overlay `position: fixed; inset: 0`;
- modal z-index вище нижньої навігації;
- `role="dialog"`;
- `aria-modal="true"`;
- Escape/close працює;
- scroll lock cleanup;
- 0 orphan overlays.

Не показувати користувачу:

```
Plain Text

SYSTEM FAILURE
Failed to fetch dynamically imported module
```

Для lazy chunk додати Error Boundary і контрольований retry/reload.

---

11. P1 — Безпека

Перевірити в source і Cloudflare production:

- bot token;
- Supabase service role key;
- API keys;

- admin credentials;
- private wallet keys;
- secrets у localStorage;
- `isPro` у Zustand persist;
- `tg_user` fallback;
- fake payment mode;
- fake wallet mode;
- admin role у frontend;
- open redirects;
- untrusted `window.open`;
- payment payload replay;
- duplicate charge id;
- webhook signature/secret;
- rate limiting;
- logs із Telegram initData.

Особливо видалити production fallback:

```
Plain Text
userId: "tg_user"
```

Якщо він потрібен для test mode, він повинен існувати лише у локальному environment і бути недосяжним на production host.

---

12. Cloudflare deployment checklist

Google AI Studio має не лише зробити commit, а перевірити Cloudflare deployment.

Після push:

1. Переконатися, що Cloudflare Pages build завершився успішно.
2. Перевірити deployment commit SHA.
3. Перевірити production asset hash.
4. Переконатися, що `/functions/api/*` реально deployed.

5. Перевірити, що `/api/*` не перехоплюється SPA fallback.
6. Додати secrets у Cloudflare Pages Functions environment, а не у frontend variables.
7. Перевірити production logs.
8. Зробити cache purge або atomic deployment.
9. Перевірити live URL після deploy, а не лише localhost/preview.
10. Не вважати GitHub commit доказом production deployment.

---

13. Готове завдання для Google AI Studio

Скопіюй цей блок як окремий prompt:

Plain Text

```
Виконай повний production-fix StorkCrypto. Працюй не лише в локальному preview:

P0:
1. Прибери production fallback userId="tg_user".
2. /api/payments/stars/create повинен повертати 401 без валідного Telegram initl
3. Перевіряй Telegram initData HMAC server-side.
4. Не приймай userId, amount, currency або plan як довірені frontend-поля.
5. Реалізуй Stars invoice currency XTR.
6. Реалізуй pre_checkout_query з відповіддю протягом 10 секунд.
7. Реалізуй successful_payment webhook.
8. Перевіряй payload, Telegram user id, amount, currency і telegram_payment_cha
9. Додай unique/idempotent payment record.
10. PRO активуй тільки після успішної server-side верифікації successful_paymen
11. /api/payments/stars/status має бути реальною Cloudflare Function і повертат
12. Відсутня auth → 401; невідомий order → 404; чужий order → 403.

TON WALLET:
13. Додай один root TonConnectUIProvider.
14. Додай public /tonconnect-manifest.json.
15. Замініть JPG icon на public PNG 180x180.
16. У Portfolio додай Connect TON Wallet.
17. Після onStatusChange(wallet) автоматично закривай picker.
18. Показуй Connected, shortened wallet address, wallet name, Copy, Explorer, D
19. useIsConnectionRestored використовуй до показу Disconnected.
20. Не активуй PRO після wallet connection.

WEB:
21. Додай web button Pay via Telegram.
22. Створюй invoice link server-side.
```

23. Відкривай Telegram invoice через дозволений redirect/open link.
24. Після повернення polling роби тільки через authenticated order status API.
25. Не показуй success після redirect або query param.

DATA/UI:
26. Якщо дані з cache — показуй STALE/DELAYED з lastUpdatedAt, не LIVE.
27. Виправ Academy UA/EN/RU так, щоб змінювався весь текст карток, lessons, tag
28. Виправ усі lazy import/chunk errors і додай Error Boundary.
29. Усі технічні та informational modals зроби fullscreen; PRO — єдиний компакт
30. Проведи 30 open/close cycles без orphan overlay.

DESIGN:
31. Працюй як Chief Design Developer.
32. Збережи dark, premium, non-multicolor crypto-terminal identity.
33. Не збільшуй логотип StorkCrypto надмірно.
34. Збережи vertical 6.5-second Manifesto loading screen.
35. Не використовуй GENESIS.
36. Використовуй rotating concentric rings, які при 100% трансформуються у Stor
37. Дозволений horizontal data convergence ending.
38. Не використовуй semicircle disappearance.
39. Fog/pixel/fracture effects мають бути плавними, контрольованими та читабель
40. StorkCrypto має поміщатися в один рядок на 360x800.
41. Мінімально збільш основні шрифти й indicators приблизно на 10% без layout o

CLOUDFLARE:
42. Перевір реальний deployment commit SHA.
43. Перевір, що Functions deployed у production.
44. Перевір secrets у Cloudflare environment.
45. Перевір, що /api routes не падають у SPA fallback.
46. Після deploy протестуй live URL у чистій сесії.

FINAL SELF-AUDIT:
47. Hard reload/loading timing.
48. Mobile 360x800 і 390x844.
49. Day/Night 5 разів.
50. Academy UA/EN/RU.
51. AI Chat 10 запитів, HTTP 200.
52. Stars create без initData → 401.
53. Stars create з валідним initData → PENDING order.
54. successful_payment → PRO active.
55. Duplicate webhook → no duplicate subscription.
56. Wallet connect/disconnect 30 разів.
57. Modal open/close 30 разів.
58. Console/network без uncaught errors.
59. Security scan production bundle.
60. Перевір live Cloudflare після build.

Фінальний звіт надай у форматі:

```
- що виправлено;
- які файли змінено;
- Cloudflare deployment SHA;
- API status results;
- Stars lifecycle results;
- TON Connect results;
- modal stress test results;
- design/loading results;
- залишкові ризики;
- READY або NOT READY.

Не став READY, якщо Stars successful_payment не підтверджений server-side, stat
```

---

14. Фінальний висновок

Поточний live deployment уже має робочий AI Chat і великий список Terminal assets. Водночас payment endpoint зараз має неприйнятний demo/auth fallback, а status endpoint фактично не є API. Це пояснює, чому користувацька оплата не працює повноцінно і чому GitHub commit не означає завершену Cloudflare інтеграцію.

До виправлення P0 застосунок не можна випускати для реальних користувачів і не можна вважати Stars payment production-ready.

References

[1] Telegram Stars payments for digital goods and services
[2] TON Connect overview
[3] TON Connect get started and manifest requirements
[4] Telegram Mini Apps WebApp openInvoice
[5] Telegram Blockchain Guidelines